

Security Linter Report

Filename	case4_sql_i_printf.py
Timestamp	2026-05-04 19:12:27 UTC
Lines of Code (LOC)	3
Verdict	VULNERABLE

ID	Severity	Sink	Source Variable	Source Type	Line
CVE-SL-002	CRITICAL	db.execute	sql	HTTP_ARGS	3

CRITICAL	1
WARNING	0
INFO	0
TOTAL	1

CVE-SL-002 — db.execute**CRITICAL**

CWE	CWE-89
Sink	db.execute
Sink Line	3
Sink Column	0
Sink Expression	db.execute(sql)
Argument	sql
Source Variable	sql
Source Type	HTTP_ARGS
Propagation Mechanism	direct assignment from HTTP request

Taint Path Trace:

Step	Role	Line	Expression
1	SOURCE	2	sql = "SELECT id FROM accounts WHERE login = '%s'" % usernam...
2	SINK	3	db.execute(sql)

Remediation:

Use a parameterized query. Never interpolate HTTP parameters directly into SQL:

```
name = request.args.get("name")
query = "SELECT * FROM users WHERE name = %s"
cursor.execute(query, (name,))
```

No safe sink paths confirmed.

No sanitization functions detected.

CFG — Total Nodes	5
CFG — Condition/Loop Nodes	0
CFG — Assignment Nodes	2
CFG — Call Nodes	1
CFG — Merge Nodes	0
██	██████████
DFG — Total Nodes	12
DFG — Total Edges	11
DFG — Source Nodes	3
DFG — Sink Nodes	1
DFG — Operator Nodes	1
DFG — Constant Nodes	2
DFG — Variable Nodes	5
Taint Propagation Hops	5
██	██████████
Analysis Time (ms)	14.1

Vulnerabilities	1 CRITICAL 0 WARNING 0 INFO
Safe Sinks	0
Analysis Time	14.1 ms
Engine Version	1.0.0
Final Verdict	VULNERABLE